



XecureCrypto v2.2.0.0

보안정책서

HANCOM WITH Inc.

4FL Hancom Tower, 49 Deawangpangyo-ro 644 Beon-gil,
Sampyeong-dong, Bundang-gu, Seongnam-si Gyeonggi-do, Korea, 13493

Revision History

Version	Date	Author	Revisions Made
1.0	2024-05-09	이 철 이창석	보안정책서 신규 작성
1.1	2025-05-30	길광은	XecureCrypto v2.2.0.0 재검증

목차

1. 개요	4
1.1 보안수준	4
2. 암호모듈 명세	5
2.1 검증대상/비검증대상 알고리즘	5
2.2 동작모드	7
3. 암호모듈 인터페이스	8
4. 역할, 서비스 및 인증	9
5. 소프트웨어 보안	11
6. 운영 환경	12
7. 중요 보안매개변수 관리	13
8. 물리적 보안	15
9. 비침투 보안	16
10. 자가시험	17
11. 생명주기 보증	18
12. 기타 공격에 대한 대응	19
13. 보안정책 및 사용지침	20
13.1 보안정책	20
13.2 사용지침	20

1 개요

본 문서는 ㈜한컴위드의 XecureCrypto v2.2.0.0 암호모듈에 대한 보안정책을 기술하고 있다.

1.1 보안수준

XecureCrypto v2.2.0.0 암호모듈은 암호모듈 검증기준(KS X ISO/IEC 24759:2015)의 영역별 보안 요구사항에 대하여 물리적 보안, 비침투 보안을 제외한 모든 보안 요구사항에 대하여 보안수준1을 충족한다.

보안 요구사항	보안수준
암호모듈 명세	1
암호모듈 인터페이스	1
역할, 서비스 및 인증	1
소프트웨어/펌웨어 보안	1
운영환경	1
중요 보안매개변수 관리	1
물리적 보안	n/a
비침투 보안	n/a
자가시험	1
생명주기 보증	1
기타 공격에 대한 대응	1

표 1. 보안수준

2 암호모듈 명세

XecureCrypto v2.2.0.0 암호모듈은 C 언어 기반으로 개발된 동적 라이브러리 형태의 소프트웨어 암호모듈로써 동적 객체(.dll : Windows, .so : Linux/Solaris/AIX/Android, .sl : HP-UX, .dylib : Mac OS, iOS) 형태로 구성되어 있다. XecureCrypto v2.2.0.0 은 검증대상 알고리즘과 비검증대상 알고리즘을 포함하며 각 동작모드의 암호 알고리즘은 다음과 같다.

2.1 검증대상/비검증대상 알고리즘

구분	검증대상 알고리즘		표준
블록암호	ARIA	$ k =128,192,256$ 운영모드=ECB,CBC,CFB,OFB,CTR,CCM,GCM	KS X 1213
	SEED	$ k =128$ 운영모드=ECB,CBC,CFB,OFB,CTR,CCM,GCM	TTAS.KO-12.004/R1
해시함수	SHA-2	SHA-224/256/384/512	ISO/IEC 10118-3 NIST FIPS 180-4
	SHA-3	SHA3-224/256/384/512	ISO/IEC 10118-3 NIST FIPS 202
메시지인증	HMAC	SHA-224/256/384/512 SHA3-224/256/384/512	ISO/IEC 9797-2 RFC 2104
난수발생기	HASH DRBG	SHA-256	ISO/IEC 18031 NIST SP 800-90A
공개키암호	RSAES	$ n =2048$ Hash=SHA-224/256	ISO/IEC 18033-2 RFC 8017 NIST FIPS 186-4
전자서명	RSA-PSS	$ n =2048$ Hash=SHA-224/256	ISO/IEC 9796-2 RFC 8017 NIST FIPS 186-4
	KCDSA	$ p =2048, 3072$ $ q =256$ Hash=SHA-256	TTAK.KO-12.0001/R4 NIST FIPS 186-4
	ECDSA	Curve=P-224,P-256,B-233,B-283,K-223,K283 Hash=SHA-224/256	ISO/IEC 14888-3 RFC 6979 NIST FIPS 186-4
키 설정	DH	$ p =2048$ $ q =224, 256$	ISO/IEC 11770-4 RFC 2631
	ECDH	Curve=P-224,P-256,B-233,B-283,K-223,K283	ISO/IEC 15946-1

			RFC 4492 NIST SP 800-56A
키 유도	PBKDF	HAMC-SHA224/256/384/512	TTAK.KO-12.0334

표 2. 검증대상 알고리즘

구분	비검증대상 알고리즘		표준
블록암호	AES	$ k =128,192,256$ 운영모드=ECB,CBC,CFB,OFB,CTR,CCM,GCM	NIST SP 800-38A NIST FIPS 197
해시함수	SHA-1	-	ISO/IEC 10118-3
	HAS-160	-	ISO/IEC 10118-3
	RIPEMD160	-	ISO/IEC 10118-3
메시지인증	HMAC	SHA1, HAS-160, RIPEMD160	ISO/IEC 9797-2
	CBCMAC	Algorithm=AES, SEED	ISO/IEC 9797-1 NIST FIPS 800-38B
공개키암호	RSA-PKCSv1.5	$ n =2048,3072$ Hash=SHA1,SHA256,SHA384,SHA512	ISO/IEC 9796-2 RFC 2313, 8017
전자서명	RSA-PKCSv1.5	$ n =2048,3072$	RFC 2313, 8017 NIST FIPS 186-4
	DSA	$ p =2048, q =256$ Hash=SHA-256	ISO/IEC 14888-3 NIST FIPS 186-4 RFC 6979
	KCDSA	$ p =1024, q =160$ Hash=SHA1,HAS160,SHA256/384/512	TTAK.KO12.0001/R4 ISO/IEC 14888-3

표 3. 비검증대상 알고리즘

* 비검증대상 알고리즘 중에서 노후 알고리즘은 민간제품의 하위호환성을 제공하기 위해서만 사용해야 하며 그 외 용도로 사용하는 것은 지양해야 한다.

* 비검증대상 알고리즘 중 노후 알고리즘은 블록암호 알고리즘 AES 128, 해시 알고리즘 SHA224, 공개키 알고리즘 RSA 2048 보다 낮은 보안강도를 가지는 암호 알고리즘을 의미한다.

* 2개 이상의 알고리즘으로 구성된 암호 알고리즘의 경우 가장 낮은 보안강도를 가지는 알고리즘을 기준으로 보안강도를 판단한다.

2.2 동작모드

XecureCrypto v2.2.0.0 암호모듈은 검증대상 동작모드와 비검증대상 동작모드 운영을 지원

하며, 각 지원 알고리즘은 상기 '표2. 검증대상 알고리즘' 및 '표3. 비검증대상 알고리즘'과 같다. 사용자가 암호모듈을 적재한 후 초기화를 수행하면 암호모듈은 내부적으로 자가시험을 수행하며 자가시험에 실패하는 경우 암호모듈은 오류 상태로 전환되어 암호모듈을 사용할 수 없다. 자가시험에 성공 후 암호모듈을 사용하는 경우 사용자는 검증대상 동작모드와 비검증대상 동작모드를 전환할 수 있으며, 동작모드 전환시에도 동작모드 방향과 무관하게 자가시험을 수행하며 자가시험에 성공해야 전환된 동작모드에서 암호모듈을 사용할 수 있다.

3 암호모듈 인터페이스

XecureCrypto v2.2.0.0 은 논리적 인터페이스를 통해 모든 제어가 수행되며 물리적 접근을 통한 제어는 제공하지 않는다. XecureCrypto v2.2.0.0 의 논리적 인터페이스 구성은 '표 4. 암호모듈 논리적 인터페이스'와 같다.

구분	논리적 인터페이스
데이터 입력	함수 호출 시 함수 인자를 통해서 모듈에서 사용될 데이터가 모듈로 전달된다.
데이터 출력	함수 호출 시 명시된 결과값을 받을 함수 인자를 통해 출력 값이 전달된다.
제어 입력	함수 호출 시 모듈 시작, 종료, 암호 운영, 상태 변화를 위한 제어가 전달된다.
상태 출력	함수 호출 시 동작 수행 후 함수의 리턴 값을 통해 전달된다.
전원	해당 없음

표 4. 암호모듈 논리적 인터페이스

4 역할, 서비스 및 인증

XecureCrypto v2.2.0.0 암호모듈은 암호모듈 검증기준 보안수준 1의 보안 요구사항에 따라 사용자 역할과 암호 관리자 역할을 구분하고 있다. 다만 XecureCrypto v2.2.0.0 암호모듈은 소프트웨어 형태의 라이브러리로 사용자와 암호 관리자 역할은 수행하는 서비스에 따라 논리적으로 분리되며 물리적으로는 사용자와 관리자가 같은 신분일 수 있다. 각 역할에 대한 설명 및 역할에 따른 허용 서비스는 각각 '표 5. 역할 정의' 및 '표 6. 허용 서비스'와 같다.

역할	설명
사용자	XecureCrypto v2.2.0.0 암호모듈에서 제공하는 모든 서비스에 접근할 수 있는 주체를 말한다. 사용자 역할은 암호모듈에서 제공하는 API를 호출하여 서비스를 이용하는 것이다.
암호 관리자	XecureCrypto v2.2.0.0 암호모듈을 컴퓨터 시스템에 설치하고 운영체제를 설정하며, 설치된 암호모듈의 서비스를 사용할 수 있는 주체이다. 암호 관리자는 사용자가 사용할 수 있는 모든 서비스에 접근 가능하나, 암호 관리자는 키 혹은 데이터에 특별히 접근할 수 있는 권한이 없다. XecureCrypto v2.2.0.0 암호모듈을 설치하고 운영체제를 설정하는 역할을 가진다. XecureCrypto v2.2.0.0 암호모듈은 단일 운영자만을 지원하며, 운영자는 운영체제의 접근 권한 설정을 이용하여 인가되지 않은 접근 시도를 차단한다.

표 5. 역할 정의

서비스	설명	역할
관리	암호모듈 배포 및 설치	관리자
	암호모듈 초기화	관리자/사용자
	암호모듈 상태 출력	관리자/사용자
	암호모듈 정보 출력	관리자/사용자
	암호모듈 동작모드 전환	관리자/사용자
	주기적 자가시험 수행	관리자/사용자
블록암호	검증대상/비검증대상 동작모드에서 대칭키 생성	관리자/사용자
	검증대상/비검증대상 동작모드에서 블록 암호/복호화 수행	관리자/사용자
해시함수	검증대상/비검증대상 동작모드에서 해시 생성	관리자/사용자

메시지 인증	검증대상/비검증대상 동작모드에서 메시지 인증 코드 생성	관리자/사용자
난수발생기	검증대상/비검증대상 동작모드에서 난수 생성	관리자/사용자
공개키 암호	검증대상/비검증대상 동작모드에서 키쌍 생성	관리자/사용자
	검증대상/비검증대상 동작모드에서 공개키 암호/복호화 수행	관리자/사용자
전자서명	검증대상/비검증대상 동작모드에서 전자서명 생성 및 검증 수행	관리자/사용자
키 설정	검증대상/비검증대상 동작모드에서 키 설정 알고리즘을 통한 키 설정 수행	관리자/사용자
키 유도	검증대상/비검증대상 동작모드에서 키 유도 알고리즘을 통한 키 생성 수행	관리자/사용자

표 6. 허용 서비스

5 소프트웨어 보안

XecureCrypto v2.2.0.0 암호모듈은 소프트웨어의 위/변조 방지를 위해 XecureCrypto v2.2.0.0 암호모듈 초기화 시점에 RSA-PSS 전자서명 알고리즘을 사용한 무결성 검증을 수행한다. 이때 무결성 검증에 실패하는 경우 암호모듈은 자동으로 '심각한 오류' 상태로 상태전환이 수행되어 XecureCrypto v2.2.0.0 암호모듈을 더 이상 사용할 수 없도록 하여 XecureCrypto v2.2.0.0 암호모듈의 위/변조를 방지한다.

6 운영환경

XecureCrypto v2.2.0.0 암호모듈이 지원하는 운영환경은 '표 7. 운영환경'과 같다.

운영체제	세부 구분	암호모듈명
Windows Server 2016	64bit	libXecureCrypto.dll
Windows Server 2019	64bit	libXecureCrypto.dll
Windows 10	64bit	libXecureCrypto.dll
Windows 10	32bit	libXecureCrypto.dll
RHEL 8 (8.5 Oopta)	64bit	libXecureCrypto.so
ubuntu 20.04 (20.04.3 Focal Fossa)	64bit	libXecureCrypto.so
Solaris 10(sparc) (10.9 sparc)	64bit	libXecureCrypto.so
Solaris 10(x86) (10.10 amd64)	64bit	libXecureCrypto.so
Solaris 11(sparc) (11.4 sparc)	64bit	libXecureCrypto.so
Solaris 11(x86) (11.4 amd64)	64bit	libXecureCrypto.so
HP-UX 11i v3 (ia-64)	64bit	libXecureCrypto.sl
AIX v7.2 (7.2 ppc)	64bit	libXecureCrypto.so
Android 13 (arm64)	64bit	libXecureCrypto.so
MacOS 14.3.1 (M1 arm64)	64bit	libXecureCrypto.dylib
iOS 16.7.3 (A11 arm64)	64bit	libXecureCrypto.dylib

표 7. 운영환경

7 중요 보안매개변수 관리

XecureCrypto v2.2.0.0 암호모듈의 중요 보안매개변수 및 공개 보안매개변수는 각각 '표 8. 중요 보안매개변수' 및 '표 9. 공개 보안매개변수'와 같다.

중요 보안매개변수	알고리즘 (비검증대상 알고리즘 포함)	설명
블록암호 대칭키	ARIA, SEED, AES	대칭키 알고리즘
	HMAC, CBCMAC	메시지 인증 코드 알고리즘
블록암호 라운드키	ARIA, SEED, AES	블록암호 라운드키
개인키	RSA	RSA 공개키 알고리즘용 개인키
	KCDSA, ECDSA, DSA	서명 알고리즘용 개인키
	DH, ECDH	키 설정 알고리즘용 개인키
공유키	DH, ECDH	키 설정 알고리즘을 통한 공유키
난수 발생기	Hash_DRBG	엔트로피 입력, 내부상태
키 유도 키	PBKDF	PBKDF 키 유도 키

표 8. 중요 보안매개변수

공개 보안매개변수	설명
공개키	RSA, DSA, KCDSA, ECDSA, DH, ECDH 각 알고리즘의 공개키
무결성 시험용 공개키	무결성 시험용 공개키

표 9. 공개 보안매개변수

XecureCrypto v2.2.0.0의 중요 보안매개변수는 생성, 설정, 주입, 출력, 저장, 제로화 관점에서 정리하면 '표 10. 중요 보안매개변수 관리'와 같다.

중요 보안매개변수	생성	설정	주입	출력	저장	제로화
블록암호 대칭키	○	X	X	X	X	○
블록암호 라운드키	○	X	X	X	X	○
개인키(공개키 알고리즘)	○	X	X	X	X	○
개인키(키 설정 알고리즘)	○	X	X	X	X	○
공유키(키 설정 알고리즘)	X	○	X	X	X	○
난수발생기 엔트로피 입력	X	X	X	X	X	○

난수발생기 내부상태(V,Key)	O	X	X	X	X	O
PKBDF 유도 키	O	X	X	X	X	O

표 10. 중요 보안매개변수 관리

8 물리적 보안

해당사항 없음

9 비침투 보안

해당사항 없음

10 자가시험

XecureCrypto v2.2.0.0 암호모듈이 적재되면 자동적으로 암호 모듈이 바르게 작동하는지 검사하기 위한 동작 전 자가시험이 자동으로 수행된다. 이때 동작 전 자가시험을 수행하기 위한 어떠한 입력도 필요로 하지 않는다. 동작 전 자가시험은 운영체제가 암호모듈 파일을 메모리에 적재한 뒤 가장 처음 호출하는 함수 내부에서 수행되기 때문에 어떠한 다른 암호 연산도 시험 중에 수행되지 않는다. 따라서 데이터 출력 인터페이스를 통하는 모든 데이터 출력은 시험이 수행되는 동안 금지된다. 만약 동작 전 자가시험이 실패할 경우에는 XecureCrypto v2.2.0.0 암호모듈은 심각한 오류 상태가 되고 모든 암호화 연산은 차단된다. 전반적인 자가시험에 대한 내용을 요약하면 '표 11. 자가시험'과 같다.

구분	시험항목	시험수행시기
동작 전 자가시험	암호 알고리즘 시험	모듈시작시
	소프트웨어 무결성 시험	모듈시작시
조건부 자가시험	엔트로피 건전성 시험	잡음원 수집시
	키 쌍 일치 시험	키 쌍 생성 함수 호출시
주기적 자가시험	암호 알고리즘 시험	관리자 및 사용자 API 호출시
	소프트웨어 무결성 시험	관리자 및 사용자 API 호출시

표 11. 자가시험

11 생명주기 보증

XecureCrypto v2.2.0.0 암호모듈은 인가된 운영자에게 배포되며 구체적인 배포 및 운영 방안은 다음과 같다.

구분	세부 설명
배포	암호모듈 요청 시 대면으로 암호모듈 관리자를 확인한 후 USB등의 물리적으로 격리된 저장장치를 사용하여 배포하며, 인가된 관리자에게 암호모듈을 배포한다.
무결성 검증	관리자는 KCMVP 검증필 암호모듈 목록에 게시되어 있는 XecureCrypto v2.2.0.0 암호모듈의 해시값을 비교하여 암호모듈의 무결성을 검증한다.
설치 및 운용	관리자는 '암호모듈 사용 설명서'를 참고하여 암호모듈의 적재 및 초기화를 수행하고 암호모듈을 사용한다.
이력관리	배포된 암호모듈의 적용 제품 / 배포처 / 담당자에 대한 이력을 별도로 관리하여 무분별한 요청과 암호모듈 유출을 방지한다.
장애 대응	최초 장애 접수 후 가능한 빠른 시간 내에 처리 및 응대한다. 장애 발생 시 방문 또는 유/무선 연락을 통하여 문제 해결을 지원한다.
교육지원	'암호모듈 사용 설명서'를 제공하고 계약에 따라 암호모듈 관리자 요청에 의한 교육을 지원한다.
기술지원	사용자 요청 시 방문 또는 유/무선으로 기술지원을 수행한다.

표 12. 생명주기 보증

12 기타 공격에 대한 대응

XecureCrypto v2.2.0.0 암호모듈은 정적 분석 도구를 활용하여 잘 알려진 코드레벨 취약성에 대한 대응을 하였으며, RSA 알고리즘과 KCDSA 알고리즘 및 ECC 알고리즘에 대해서 부채널 공격 대응기법을 적용하였다.

13 보안정책 및 사용지침

13.1 보안정책

XecureCrypto v2.2.0.0 암호모듈은 암호모듈 시험기준(KKS X ISO/IEC 19790:2015)의 보안수준 1 을 충족하는 암호모듈로써 다음의 보안정책을 따른다.

1. 암호모듈 운영자 역할은 논리적으로 관리자와 사용자로 구분된다.
2. 암호모듈은 별도의 인증 메커니즘을 제공하지 않는다.
3. 관리자는 암호모듈 운영 중에 암호모듈의 주기적 자가시험 기능을 사용하여 원하는 시점에 자가시험을 수행할 수 있다.
4. 암호모듈 적재 직후 동작 전 자가시험이 자동으로 수행되며, 수행에 따른 후처리는 본 문서의 '10 자가시험'의 내용에 따른다.
5. 암호모듈이 오류상태로 천이 된 경우 데이터 출력은 불가능하다.
6. 암호모듈은 중요 보안매개변수를 출력하지 않는다.
7. 암호모듈에서 정의된 데이터 입출력 인터페이스로만 데이터 입출력을 수행할 수 있다.
8. 암호모듈이 '서비스 불가' 상태이거나 '심각한 오류' 상태이면 중요 보안매개변수는 제로화된다.
9. 키 생성(대칭키, 비대칭키)이 필요한 경우 반드시 암호모듈에서 제공하는 별도의 키 생성 인터페이스를 통하여 생성하여야 한다.
10. 비검증대상 알고리즘 중에서 노후 알고리즘은 민간제품의 하위호환성을 위해서만 사용해야 하며 그 외 용도로 사용하는 것은 지양한다.
11. 무결성 검증 데이터는 암호모듈 라이브러리 내 포함되어 있다.
12. 무결성 검증용 서명생성키는 '㈜한컴위드'의 키 관리 정책에 따라 안전하게 관리된다.

13.2 사용지침

XecureCrypto v2.2.0.0 암호모듈은 본 문서 및 '암호모듈 사용 설명서'에 따라 사용해야 한다.